SPIKA TECH™

PROCEDIMIENTO DE AUDITORÍAS

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025 con	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 PLAN DE AUDITORÍA INTERNA 4
5 REALIZACIÓN DE AUDITORÍAS 5
6 INFORME DE AUDITORÍA 6
7 PLAN DE ACCIÓN 7
8 REFERENCIAS 7

1 OBJETIVO

El objeto del presente procedimiento es definir las pautas para llevar a cabo con eficacia el proceso de auditoría del Sistema de Gestión de Seguridad de la Información establecido en SPIKA TECH, con el fin de verificar su implantación y su efectividad y evaluar el grado de conformidad con las Normas aplicables y con los propios requisitos del Sistema, detectando los incumplimientos y permitiendo establecer las acciones correctivas para eliminarlos.

2 ALCANCE

Este procedimiento se aplica en todos los sistemas de información de los servicios de ciberseguridad de SPIKA TECH, que dan soporte a los servicios especificados que se incluyen en cada ámbito de actuación de los Sistemas de Gestión de Seguridad de la Información (SGSI)

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance.

4 PLAN DE AUDITORÍA INTERNA

Anualmente, el Área de Ciberseguridad debe planificar las auditorías a realizar sobre el Sistema de Gestión de su competencia.

Esta programación se documenta basándose en:

- Se produzcan cambios significativos en el sistema de gestión.
- Cambios derivados de nuevas tecnologías.
- Evolución de los indicadores.
- Informes de acciones correctivas.
- Informes de no conformidad.
- Se sospeche o se tenga certeza de que el nivel de cumplimiento de los requisitos legales y normativos está comprometido.

- Se produzcan situaciones que así lo requieran, por ejemplo: incidentes graves de seguridad, eventos de entorno con posibles consecuencias graves, daños a la imagen, etc.
- Se desee verificar la adecuada implantación de acciones correctivas.

Como ya indicado, el SGSI es auditado en su totalidad anualmente, evaluando su situación y el resultado de las acciones correctivas anteriormente establecidas, prestando particular atención al grado de desarrollo e implantación del sistema en cuanto a su adecuación a los requerimientos que éste contiene.

Del mismo modo, se podrá planificar alguna auditoria especial o extraordinaria en función de:

- Criticidad del área afectada.
- Resultado de auditorías anteriores.
- Innovaciones producidas en relación con personas.
- Cambios en la evaluación de riesgos y políticas, etc.

El plan de auditoría contemplará tanto el sistema documental como el cumplimiento de las medidas implantadas. El plan establecerá:

- Las actividades y/o procesos de negocio que deben ser auditadas, indicando la fecha de dichas auditorías.
- Los auditores que intervienen (denominado equipo auditor). Estos deben ser personas cualificadas e independientes del área a auditar.
- Los documentos y controles por auditar.

Una vez elaborado dicho plan y aprobado, el responsable se encargará de custodiar el plan, así como de garantizar que se lleve a cabo.

5 REALIZACIÓN DE AUDITORÍAS

Para realizar la auditoría y revisión periódica del cumplimiento del SGSI, se toman como base hechos e informes de distinta naturaleza entre los que se encuentran:

- Documentación e informes sobre el propio SGSI.
- Valoración del cumplimiento.

- Cambios en la infraestructura de comunicaciones o sistemas.
- Resultados de las auditorías efectuadas (internas y externas).
- Estado de No Conformidades.
- Información suministrada por los usuarios.
- Modificaciones en la situación original del riesgo.
- Indicadores de funcionamiento de los controles / medidas de seguridad.
- Recomendaciones de mejora y perfeccionamiento.

El alcance de la auditoría debe comprender, al menos, los departamentos y activos dentro del alcance del SGSI auditado.

El auditor formulará las preguntas adecuadas en las entrevistas al auditado, obtendrá las evidencias, verificará las medidas técnicas, solicitará los documentos, etc. También examinará las evidencias incorporadas en los Registros de Control de los que cada departamento es responsable.

Efectúa las comprobaciones técnicas para verificar que las medidas-controles implantadas para reducir las vulnerabilidades de los sistemas de información y continuidad de las operaciones funcionan con eficacia anotando sus resultados.

El auditado es el responsable del Departamento / Servicio o Activo, incorporado en el SGSI como elemento a proteger. Este cooperará con el auditor facilitándole el acceso a los Registros de Incidencias, suministrando la documentación necesaria y contestando a las preguntas que el auditor le formule, de buena fe y diligentemente.

6 INFORME DE AUDITORÍA

Los resultados de la auditoría se reflejarán en el correspondiente informe, comprendiendo todos aquellos hallazgos detectados por los auditores y otros comentarios que consideren pertinentes para la mejora del sistema. La elaboración del informe de auditoría corresponde al equipo de auditoría designado. El informe de auditoría tendrá una estructura que, como mínimo, comprenda los siguientes apartados:

- Título, el destinatario del informe y la fecha en que se concluye y se entrega.
- La inadecuación de las medidas/controles implantados o las no conformidades

- debidamente especificadas.
- Los hechos, observaciones en los que se basan las no conformidades detectadas.
- Las conclusiones en cuanto a la adecuación del SGSI a los requisitos de la norma evaluada.

Los hallazgos de auditoría se calificarán atendiendo a la siguiente clasificación:

- **No conformidad:** Cualquier actividad, actuación, documentos, etc., que incumpla requisitos establecidos bien en las normas de aplicación o bien en las normas y procedimientos del SGSI.
- **Observación.** Algo que podría dar lugar a una no conformidad, si se permite que continúe sin corregir; o una condición existente sin pruebas de apoyo adecuadas para verificar que constituye una no conformidad.
- **Oportunidad de mejora.** Las oportunidades de mejora se refieren a áreas y/o procesos del SGSI que pueden cumplir con los requisitos mínimos de la norma, pero que podrían mejorarse.

7 PLAN DE ACCIÓN

El informe de auditoría se evaluará para definir y aprobar un Plan de Acción que incluirá las acciones a desarrolla para subsanar las deficiencias identificadas en la auditoría.

Este plan contemplará las acciones, responsable de las mismas y plazo para su ejecución. En el plazo de compromiso previsto, se procederá a revisar de nuevo la no conformidad con objeto de verificar la adopción de las medidas, procediendo a cerrar la auditoría en curso de forma total o parcial.

8 REFERENCIAS

- ISO 27001:2022:
    - 6.1 Acciones para tratar los riesgos y oportunidades.
    - Clausula 4.4 Sistema de gestión de la seguridad de la información.